

Denial of Service (DoS) Attack

Denial of Service Attack

- An explicit attempt by attackers to prevent legitimate users of a service from using that service.
- The attacker saturated the target machine with useless traffic so that it cannot respond or too slow to respond and some times unavailable.

Major DoS attacks

- In Feb 2000, series of massive DoS attacks incapacitated several e-commerce sites, including **Yahoo, Ebay**
- In Jan 2001, **Microsoft's name sever** infrastructure was disabled
- In Oct 2002, all **Domain Name System servers** were attacked
- In Aug 2009, the attack on **Twitter** and **Facebook**

- Threat:
 - Consumption of network connectivity and/or bandwidth
 - Consumption of other resources, e.g. queue, CPU
 - Destruction or alternation of configuration information
 - Malformed packets confusing an application, cause it to freeze
 - Physical destruction or alternation of network components

- Denial-of service attacks can essentially disable the computer or the network. Depending on the nature of the enterprise, this can disable entire organization.
- Some denial-of-service attacks can be executed with limited resources against a large, sophisticated site. This type of attack is sometimes called an **asymmetric attack**.
- For example, an attacker with an old PC and a slow modem may be able to disable much faster and more sophisticated machines or network.

- DoS attacks target:
 - Network bandwidth
 - Flood the network with high volume of traffic
 - Connectivity
 - Flood the victim with high volume of connection requests

Classification of DOS Attacks

Attack	Affected Area	Example	Description
Network Level Device	Routers, IP Switches, Firewalls	Ascend Kill II, "Christmas Tree Packets"	Attack attempts to exhaust hardware resources using multiple duplicate packets or a software bug.
OS Level	Equipment Vendor OS, End-User Equipment.	Ping of Death, ICMP Echo Attacks, Teardrop	Attack takes advantage of the way operating systems implement protocols.
Application Level Attacks	Finger Bomb	Finger Bomb, Windows NT RealServer G2 6.0	Attack a service or machine by using an application attack to exhaust resources.
Data Flood (Amplification, Oscillation, Simple Flooding)	Host computer or network	Smurf Attack (amplifier attack) UDP Echo (oscillation attack)	Attack in which massive quantities of data are sent to a target with the intention of using up bandwidth/processing resources.
Protocol Feature Attacks	Servers, Client PC, DNS Servers	SYN (connection depletion)	Attack in which "bugs" in protocol are utilized to take down network resources. Methods of attack include: IP address spoofing, and corrupting DNS server cache.

Flooding attacks

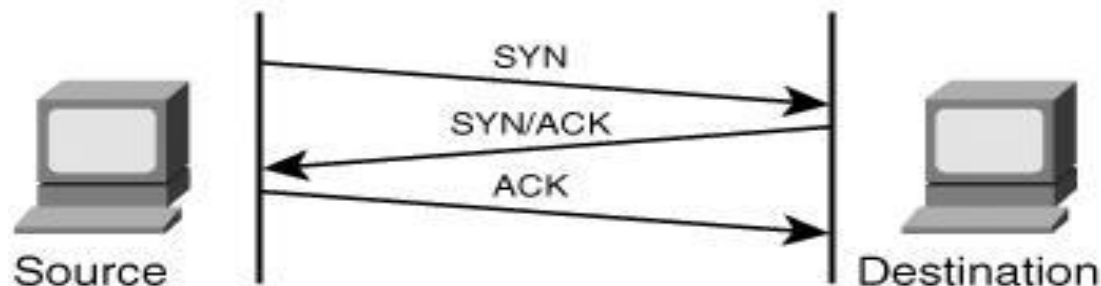
- Goal : **Bombarding large number** of malicious packets at the victim, such that processing of these packets consumes resources
- **Any type of network packet** can be used
 - Attack traffic made similar to legitimate traffic
- Valid traffic **has a low probability of surviving the discard** caused by flood and hence accessing the server
- Some ways of flooding :
 - To overload network capacity on some link to a server
 - To overload server's ability to handle and respond to this traffic
- The larger the packet, the more effective the attack

Types of flooding attacks

- Classified based on type of network protocol used to attack
 - **TCP SYN flood attack**
 - **UDP flood attack**
 - **ICMP flood attack**

SYN flood attack

- A SYN flood is one of the oldest and yet still most effective DoS attacks.
- TCP communication begins with a SYN, a SYN-ACK response, and then an ACK response.



SYN flood attack

- An attacker sends a large number of SYN requests to a target's system
 - Target uses too much memory and CPU resources to process these fake connection requests
 - Target's bandwidth is overwhelmed
- Usually SYN flood packets use spoofed source IPs
- Make the target very hard to decide which TCP SYN is attack and which TCP SYN is from legitimate users

TCP Connection Management

- Three way handshake:

Step 1: client host sends TCP SYN segment to server

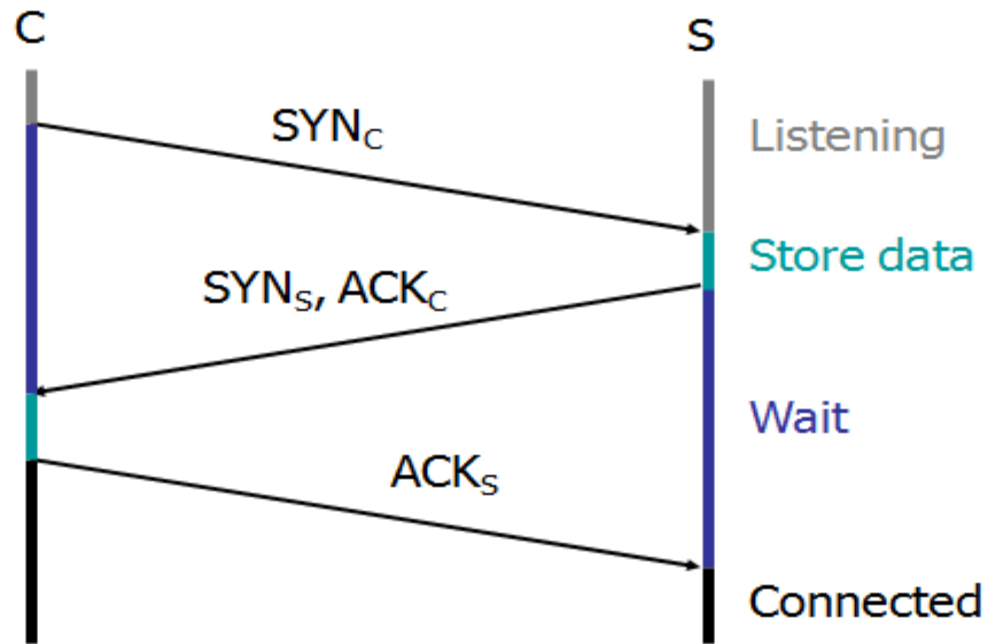
- specifies initial seq #
- no data

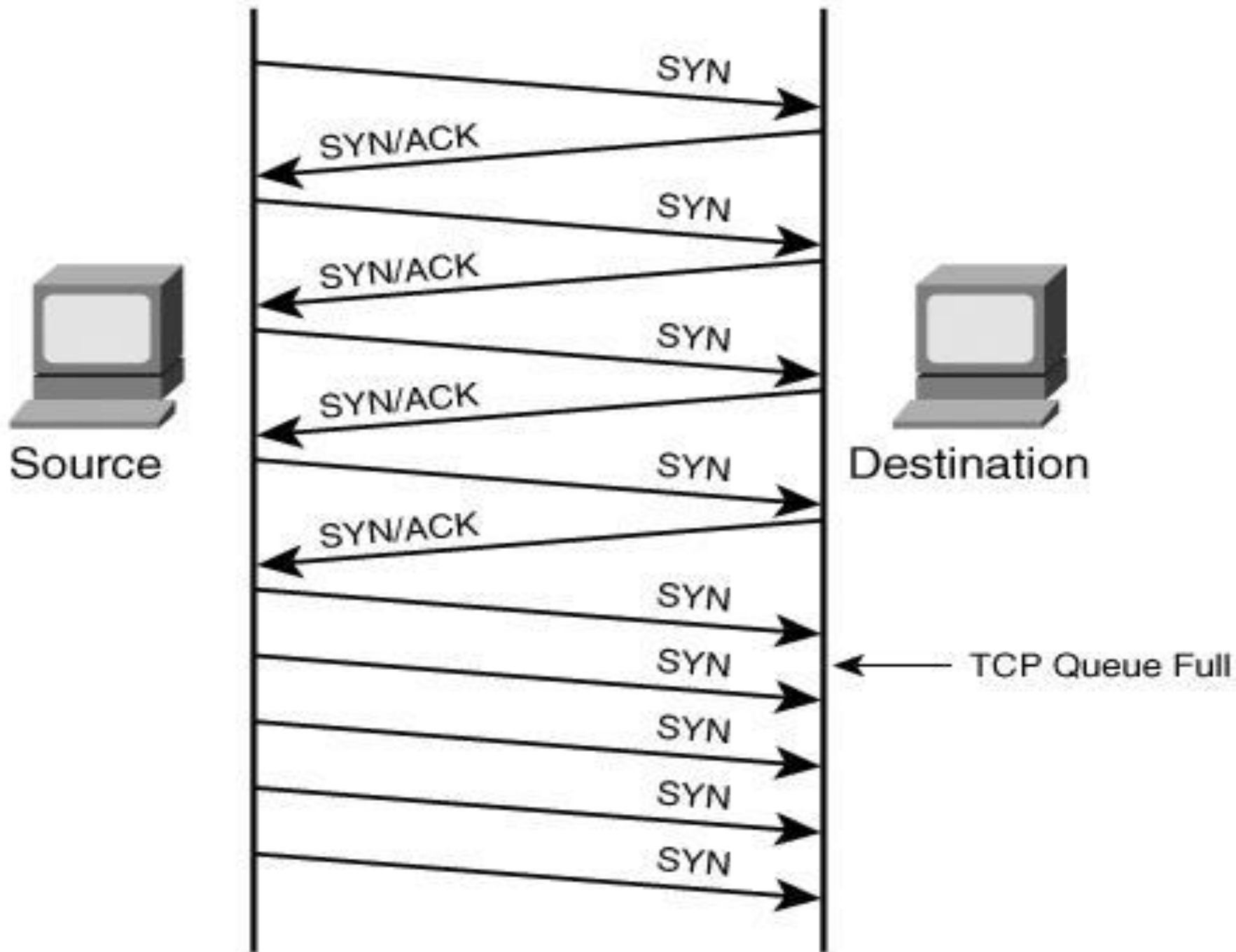
Step 2: server host receives SYN, replies with SYNACK segment

- server allocates buffers
- specifies server initial seq. #

Step 3: client receives SYNACK, replies with ACK segment, which may contain data

TCP Handshake





SYN Flooding

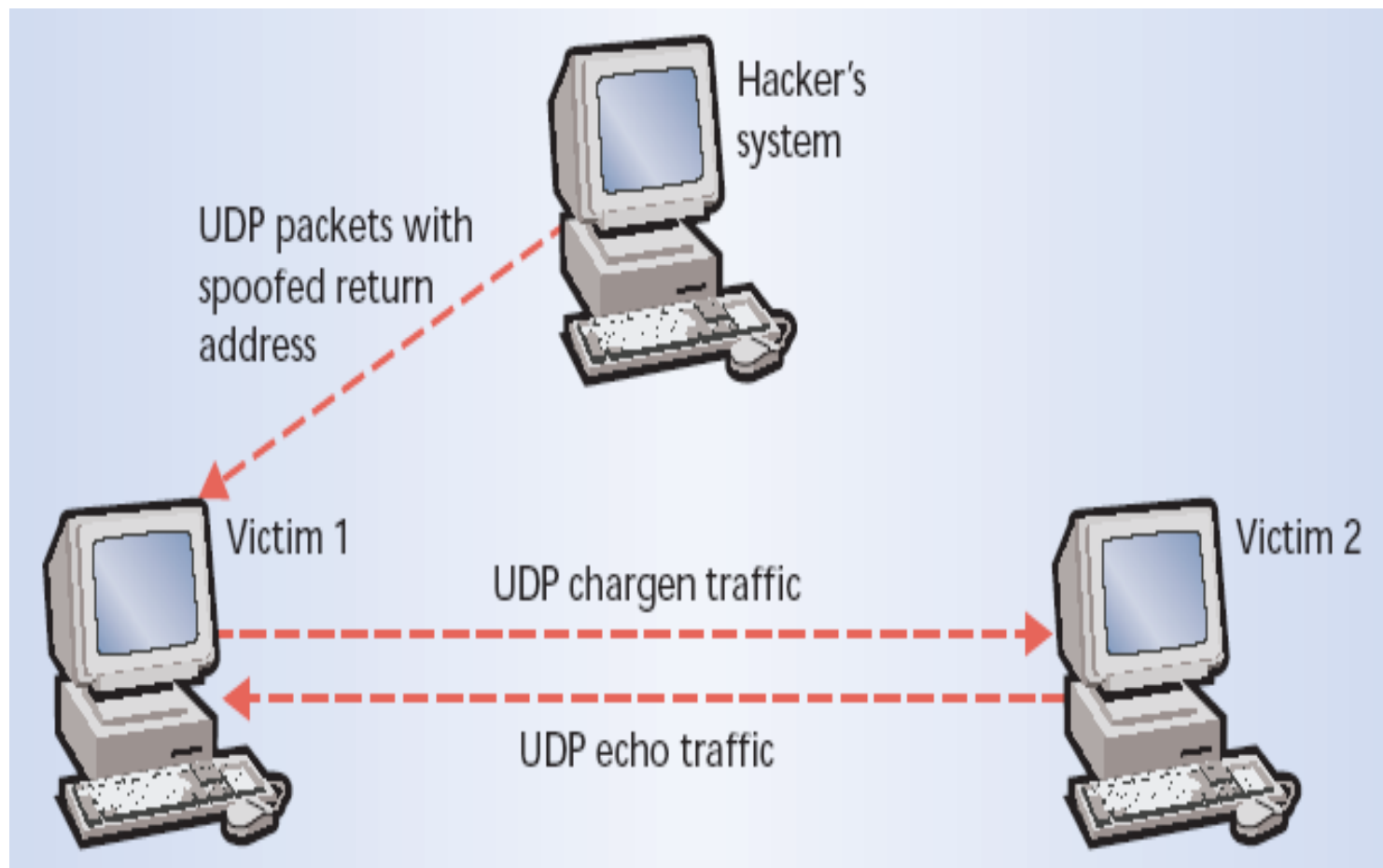
- Attacker sends many connection requests with spoofed source addresses
- Victim allocates resources for each request
 - New thread, connection state maintained until timeout
 - Fixed bound on half-open connections
- Once resources exhausted, requests from legitimate clients are denied
- The TCP/IP stack will wait a certain amount of time before dropping the connection

SYN floods are still successful today for three reasons:

- SYN packets are part of normal, everyday traffic, so it is difficult for devices to filter this type of attack.
- SYN packets do not require a lot of bandwidth to launch an attack because they are relatively small.
- SYN packets can be spoofed because no response needs to be given back to the target. As a result, attacker can choose random IP addresses to launch the attack, making filtering difficult for security administrators.

UDP flood attack

- UDP protocol is a connectionless unreliable protocol which doesn't require session negotiation between client and server application.
- UDP provides easy to use interface for producing large quantity of packets.
- UDP Flood Attacks floods the network with UDP packets destined to a victim's host.



ICMP flood attack

- Also known as **Ping Flood Attack**
- An attacker sends a huge number of **ICMP *echo request*** packets to victim.
- The victim cannot respond promptly since the volume of request packets is high and have difficulty in processing all requests and responses rapidly.
- The attack will cause the performance degradation or system down.

Other DoS attacks

- Ping of Death Attack
- TearDrop Attack
- Land Attack

Ping of Death Attack

- Ping of Death is an attempt by an attacker to crash, reboot or freeze a system by sending an illegal ICMP packet to the host under attack.
- The TCP/IP specification allows for a maximum packet size of up to 65536 octets.
- In some TCP stack implementation, encountering packets of greater size may cause the victim's host to crash.

- In the attack, the ICMP packet is sent in the form of a fragmented message which, when reassembled is larger than the maximum legal IP packet size.

TearDrop Attacks

- Teardrop attacks target a vulnerability in the way fragmented IP packets are reassembled.
- Fragmentation is necessary when IP Datagrams are larger than the maximum transmission unit (MTU) of a network segment
- An attacker sends two fragments that cannot be reassembled properly by manipulating the offset value of packet and cause reboot or halt of victim system

Land Attacks

- An attacker sends a forged packet with the same source and destination IP address.
- The victim system will be confused and crashed or rebooted.

Countermeasures for DoS Attacks

Attack	Countermeasure Options	Example	Description
Network Level Device	Software patches, packet filtering	Ingress and Egress Filtering	Software upgrades can fix known bugs and packet filtering can prevent attacking traffic from entering a network.
OS Level	SYN Cookies, drop backlog connections, shorten timeout time	SYN Cookies	Shortening the backlog time and dropping backlog connections will free up resources. SYN cookies proactively prevent attacks.
Application Level Attacks	Intrusion Detection System	GuardDog, other vendors.	Software used to detect illicit activity.
Data Flood (Amplification, Oscillation, Simple Flooding)	Replication and Load Balancing	Akamai/Digital Island provide content distribution.	Extend the volume of content under attack makes it more complicated and harder for attackers to identify services to attack and accomplish complete attacks.
Protocol Feature Attacks	Extend protocols to support security.	ITEF standard for itrace, DNSSEC	Trace source/destination packets by a means other than the IP address (blocks against IP address spoofing). DNSSEC would provide authorization and authentication on DNS information.

Defenses against DoS attacks

- DoS attacks cannot be prevented entirely
- Three lines of defense against DoS attacks
 - Attack prevention and preemption
 - Attack detection and filtering
 - Attack source traceback and identification

Attack prevention

- Limit ability of systems to send spoofed packets
 - Filtering done as close to source as possible by routers/gateways
 - Reverse-path filtering ensure that the path back to claimed source is same as the current packet's path
 - Ex: On Cisco router “ip verify unicast reverse-path” command

- Rate controls in upstream distribution nets
 - On specific packet types
 - Ex: Some ICMP, some UDP, TCP/SYN
- Use modified TCP connection handling
 - Use SYN-ACK cookies when table full
 - Or selective or random drop when table full

- Block IP broadcasts and suspicious services
- Manage application attacks with **puzzles** to distinguish legitimate human requests.
- Good general system security practices
- Use mirrored and replicated servers when high performance and reliability required
- Separate Client and Server Addresses.

Reference

- C Douligeris, A Mitrokosta, *DDoS attacks and defense mechanisms: classification and state of the art*, Computer Network, 44 (2004), 643-666